SOFTWARE SUPPLY CHAIN & SECURITY VAULT PROJECT - STUDENT 1

System Requirements Analysis & Use Cases

Specification

1. EXECUTIVE OVERVIEW & SCOPE

This document defines the formal System Requirements Specification (SRS) and operational Use Case Scenarios for the Secure Encrypted Vault with Automated Supply Chain Pipeline. As the core analytical baseline, this specification outlines user role boundaries, functional capabilities, security non-functional parameters, and execution flows required prior to implementation.

2. USER ROLES & ACCESS CONTROL MATRIX

The system establishes strict Role-Based Access Control (RBAC) to enforce access boundaries across all modules:

User Role	Functional Responsibilities	System Permissions & Boundaries
Developer / CI	Pushes application source code and deployment packages to trigger the automated security evaluation pipeline.	Limited to pipeline initiation; zero access to vault storage, keys, or security policy management.
Security Admin	Configures vulnerability failure thresholds, manages security policies, and reviews system audit logs.	Full administrative access to security policies, logs, and cryptographic configurations.
End User	Requests downloading and decrypting stored artifacts from the secure vault.	Access conditioned upon valid GPS location and authorization verification.

3. FUNCTIONAL REQUIREMENTS (FRS)

3.1 Identity & Access Control

- **FR-1.1 (Role Authentication):** The system shall authenticate user identity and resolve role permissions prior to executing any upload, policy change, or retrieval request.
- **FR-1.2 (Session Isolation):** Decryption privileges shall be bound strictly to isolated retrieval requests without granting persistent storage access.

3.2 Supply Chain & DevSecOps Pipeline

- **FR-2.1 (Automated SBOM Generation):** Upon code push, the pipeline shall automatically extract components and produce a standardized Software Bill of Materials (SBOM).
- **FR-2.2 (Vulnerability Scanning):** The pipeline shall run automated vulnerability scanning against the generated SBOM to identify known security issues.
- **FR-2.3 (Policy-Driven Pipeline Interruption):** The system shall automatically reject and terminate the build pipeline if the vulnerability scan identifies any security flaw meeting or exceeding the pre-configured severity threshold.
- **FR-2.4 (Digital Attestation):** Upon passing vulnerability checks, the system shall execute digital signing to verify the clean artifact and generate cryptographic attestation metadata.

3.3 Encryption, Storage & Retrieval

- **FR-3.1 (Payload Encryption):** Approved artifacts shall be encrypted using AES-256 prior to entering the secure vault storage layer.
- **FR-3.2 (Geo-Fenced Decryption Gate):** Upon retrieval requests, the system shall evaluate user geographical location and block decryption if the client falls outside the authorized perimeter.

4. NON-FUNCTIONAL REQUIREMENTS (NFRS)

- **NFR-1 (Security Architecture):** All operations must follow strict security principles. Cryptographic keys must be strictly segregated from encrypted data blocks.
- **NFR-2 (Auditability & Non-Repudiation):** The system must record an immutable audit log entry for every pipeline evaluation, vulnerability failure, attestation event, and retrieval attempt (both granted and denied).
- **NFR-3 (Performance & Responsiveness):** Automated SBOM generation and vulnerability scanning must complete within standard pipeline limits, and location evaluation during retrieval must execute without noticeable delay.
- **NFR-4 (Reliability & Exception Handling):** In cases of location permission refusal or verification failure, the system must fail securely by denying access by default.

5. USE CASES & OPERATIONAL SCENARIOS

Use Case 1: Automated DevSecOps Ingestion & Attestation (UC-1)

Primary Actor: Developer / CI System | **Goal:** Validate, sign, encrypt, and store a clean code artifact.
Pre-conditions: Artifact pushed to repository; automated build pipeline active.

Main Success Scenario:

1. The developer pushes an artifact to the repository.
2. The system triggers automatic generation of a complete SBOM file.
3. The system passes the SBOM to vulnerability analysis against security policies.
4. The scanner confirms zero vulnerabilities exceeding the severity threshold.
5. The system applies a digital signature and generates provenance attestation.
6. The verified artifact is encrypted with AES-256 and stored in the Secure Vault.
7. A success status and audit record are generated.

Exceptional Flow (Vulnerability Failure):
• If a high-severity vulnerability is detected: The build pipeline halts immediately. Attestation and encryption steps are skipped, the artifact is discarded, and a failure report is sent to the developer.

Use Case 2: Geo-Gated Vault Artifact Retrieval (UC-2)

Primary Actor: End User / Data Retriever | **Goal:** Safely retrieve and decrypt an artifact from the vault.
Pre-conditions: Artifact exists in vault with valid AES-256 encryption and digital signature attestation.

Main Success Scenario:

1. The user submits a retrieval request for a specific artifact.
2. The system prompts for client GPS coordinates.
3. The user grants location access and submits valid coordinates.
4. The system evaluates client location and verifies the user is within the approved zone.
5. The system verifies the digital signature to ensure payload integrity.
6. The system decrypts the file using AES-256 and transfers it to the user.

Exceptional Flow A (Location Out of Bounds / Denied GPS):

• If the user denies GPS access, or location evaluation places the user outside the permitted radius: Decryption is blocked, access is denied, and an UNAUTHORIZED_LOCATION_ATTEMPT log is written.

Exceptional Flow B (Integrity Mismatch):

• If the digital signature verification fails: Decryption is aborted, preventing execution of compromised files.